

Cyber Tabletop Exercise

SWIFT Workstation Compromise and Suspected Fraudulent Transfers

Scenario source: Structured STIX bundle provided by user

Exercise type: Facilitated tabletop exercise

Audience: Executive, operational, treasury/payments, fraud, legal/compliance, and technical response teams

Recommended duration: 90 minutes

Classification: Internal use

1. Exercise Overview

This tabletop exercise simulates a financially motivated intrusion affecting a bank's SWIFT-connected treasury payment environment. Participants are presented with suspicious cross-border payment messages queued from a high-trust SWIFT-connected workstation outside normal business patterns. The scenario tests containment of payment fraud risk, verification of queued payment messages, coordination with counterpart institutions, executive decision-making under uncertainty, and safe restoration of SWIFT-related operations.

The exercise is derived from a STIX bundle describing a banking organization operating SWIFT-connected treasury workflows, a threat actor seeking fraudulent fund transfers, an attack pattern involving abuse of a compromised SWIFT-connected workstation, and two explicit decision-focused injects related to payment isolation and recall actions.

2. Exercise Objectives

By the end of the session, participants should be able to:

- Assess how quickly suspicious SWIFT payment activity can be identified, verified, and suppressed.
- Validate decision-making authority for isolating high-trust payment endpoints and gateways.
- Test coordination between SOC, treasury operations, fraud/financial crime, legal/compliance, and business leadership.
- Evaluate escalation thresholds for executive notification, correspondent-bank coordination, and regulatory engagement.
- Confirm how break-glass or manual payment procedures would be invoked during a containment event.
- Identify evidence preservation and recovery requirements before reconnecting SWIFT-connected systems.

- Capture lessons learned for fraud controls, queue review procedures, privileged access, and interbank recall readiness.
-

3. Scope

In scope

- SWIFT-connected payment workstation and gateway
- Treasury payment creation, approval, and transmission processes
- Payment queue validation and suppression procedures
- Fraud review and urgent recall coordination
- Security incident handling, containment, and recovery decision-making
- Internal escalation and external stakeholder communications

Out of scope

- Deep host-level forensic reconstruction
 - Product-specific SWIFT software administration details
 - Jurisdiction-specific legal advice
 - Vendor-side root cause confirmation beyond what is provided in the scenario
-

4. Participants and Roles

Core participants

- **Security Operations Center (SOC):** Triage alerts, assess compromise indicators, contain systems, preserve evidence.
- **Treasury / Payment Operations:** Review queued payment messages, validate business legitimacy, prioritize payment continuity.
- **Fraud / Financial Crime Team:** Assess exposure, coordinate suppression and recall actions, support beneficiary/counterparty outreach.
- **Legal / Compliance / Privacy:** Assess notification, recordkeeping, reporting, and legal-risk implications.
- **Executive or Crisis Management Lead:** Approve high-impact containment and continuity decisions.
- **Exercise Facilitator / Scribe:** Guide discussion and capture decisions, assumptions, gaps, and action items.

Optional participants

- IT Infrastructure / Endpoint team
 - Identity and Access Management
 - Corporate Communications
 - Correspondent banking relationship owners
 - Internal Audit / Risk Management
-

5. Rules of Engagement

- This is a no-fault learning exercise.
 - Participants should respond based on current roles, authorities, and existing processes.
 - Real incidents take priority over the exercise.
 - Assume the scenario is real unless the facilitator states otherwise.
 - Reasonable assumptions may be made where documentation or tooling details are unavailable, but assumptions should be stated clearly.
 - The purpose is to test coordination and decision-making, not product-specific technical expertise.
-

6. Scenario Background

The bank operates a high-trust treasury payment environment used to create, approve, and transmit SWIFT payment messages. Because the environment supports high-value payment flows, security and fraud controls depend on strict access control, message validation, segregation of duties, and rapid coordination between security and treasury operations.

A financially motivated intrusion crew has gained access to a SWIFT-connected workstation using compromised credentials and workstation access. Their objective is to create or queue unauthorized cross-border payment messages that appear plausible enough to survive initial review and move quickly through operational workflows.

The scenario begins when treasury operations discovers unusual queued payment messages outside expected business patterns. Participants must determine whether the activity is fraud, how broadly to contain, whether to disconnect SWIFT-connected systems immediately, how to validate pending messages, and how to coordinate recalls if suspicious messages have already moved beyond the bank.

7. Key Scenario Facts from the STIX Input

- The participant organization is a banking entity operating SWIFT-connected treasury payment workflows.
 - The targeted infrastructure is a SWIFT-connected payment workstation and gateway used to create, approve, and transmit payment messages.
 - The threat actor is a crime-syndicate-style payment fraud intrusion crew.
 - The stated attack pattern is abuse of a compromised SWIFT-connected workstation to submit fraudulent messages.
 - Inject 1 in the STIX bundle states that treasury operations finds multiple unusual cross-border payment messages queued outside normal business patterns.
 - Inject 2 states that the bank must decide whether to disconnect SWIFT-connected systems immediately, how to verify queued messages, and how to coordinate recalls with counterpart institutions.
 - Listed courses of action include isolating high-trust payment endpoints and manually verifying or recalling high-value payment messages.
-

8. Exercise Timeline and Injects

Inject 1 — Unusual Messages Queued

Simulated time: 08:30

Incident stage: Detection and triage

Primary objective: Identify suspicious payment activity and initiate the right cross-functional response

Scenario narrative

Treasury operations identifies several unusual cross-border payment messages queued from a SWIFT-connected workstation. The messages were created outside normal business patterns and do not align with expected treasury activity for the day. At least two queued payments are high-value and directed to beneficiary institutions not commonly used by the bank.

Information provided to participants

- Multiple SWIFT payment messages are visible in queue.
- Activity appears to originate from a high-trust payment workstation.
- The timing is abnormal for the relevant business unit.
- Initial operator outreach is inconclusive.
- It is not yet clear whether messages have been transmitted, only queued, or partially approved.

Discussion questions

- Who owns the initial incident declaration and severity assessment?
- What immediate actions should be taken to preserve evidence while reducing payment fraud risk?
- Who is authorized to pause approvals or suppress queued payment messages?
- What controls exist to confirm whether the messages are legitimate treasury activity?
- What notifications are required internally at this stage?
- What manual or break-glass payment procedures are available if the queue must be frozen?

Expected actions

- Declare an incident and establish an incident lead.
- Begin coordinated review between SOC, payment operations, and fraud.
- Preserve workstation, gateway, and message queue evidence.
- Halt further approval or release of suspicious payments pending validation.
- Start scoping for credential misuse, abnormal workstation access, and related activity.

Facilitator notes

Push participants to identify who can stop payment release without creating uncontrolled business disruption. Clarify whether payment suppression requires dual approval and whether fraud, operations, or executive leadership must authorize a broader halt.

Inject 2 — Containment Decision Point

Simulated time: 09:30

Incident stage: Containment and business continuity

Primary objective: Force a decision between rapid isolation and operational continuity

Scenario narrative

The bank must decide whether to disconnect SWIFT-connected systems immediately. Initial review suggests at least some queued messages are suspicious, but payment operations warns that a broad shutdown of the SWIFT-connected environment could delay legitimate, time-sensitive treasury settlements. Counterpart institutions may need rapid outreach if any messages have already been released.

Information provided to participants

- Confidence is increasing that the activity is unauthorized.
- The exact scope of workstation compromise is not yet known.
- Treasury leadership highlights potential liquidity and settlement impacts if all payment activity is paused.
- Fraud teams request urgent validation and possible recall workflows for high-value messages.

Discussion questions

- Do you isolate the SWIFT-connected workstation only, or the broader gateway and associated payment path?
- What criteria determine whether to continue limited payment operations under heightened controls?
- Who validates queued messages, and what evidence is sufficient to classify them as unauthorized?
- When do you contact counterpart institutions to request hold, reject, or recall support?
- Which executives or crisis-management stakeholders must be engaged before a full payment freeze?
- What communications are required to business lines, finance, and correspondent relationships?

Expected actions

- Decide on containment scope and document risk acceptance.
- Isolate affected endpoint(s) and credentials.
- Freeze or suppress suspicious queued messages.
- Initiate manual validation of any pending high-value or unusual cross-border transactions.
- Coordinate external outreach to counterpart institutions for potential recall or rejection.
- Establish a controlled continuity plan for priority legitimate payments.

Facilitator notes

This is the core exercise inflection point. Encourage debate around narrow versus broad isolation and whether the organization has realistic manual validation capability under time pressure.

Inject 3 — Suspicious Messages Released Before Full Containment

Simulated time: 11:00

Incident stage: Fraud response and external coordination

Primary objective: Test recall procedures and escalation under partial loss of control

Scenario narrative

Further review shows that one suspicious payment message was released before the queue freeze and is now awaiting downstream processing by a correspondent institution. Another queued message was stopped in time. Fraud analysts believe there is still a narrow window to request emergency hold or recall actions if outreach occurs immediately.

Information provided to participants

- One suspicious message left the queue before full containment.
- Beneficiary and intermediary details are available, but originator information requires confirmation.
- Payment operations is under pressure to resume some legitimate activity.
- Executives request an exposure estimate and clear options within 30 minutes.

Discussion questions

- What is the bank's immediate recall process, and who owns external outreach?
- What evidence must be collected before asserting the transfer is fraudulent?
- How do legal, compliance, and fraud coordinate messaging to counterpart institutions?
- What is the threshold for executive crisis escalation?
- How do you maintain an auditable chain of decisions while moving quickly?

Expected actions

- Launch urgent interbank outreach for hold/recall actions.
- Establish a single source of truth for message status, beneficiaries, and timing.
- Escalate to executives with options, impacts, and recommended actions.
- Continue scoping for additional fraudulent messages or compromised approvals.

Facilitator notes

Probe whether participants can distinguish between technical containment and fraud-recovery workflow ownership. Many teams can isolate a workstation but struggle to operationalize time-critical recall actions.

Inject 4 — Recovery and Safe Restoration

Simulated time: 15:00

Incident stage: Recovery and post-incident obligations

Primary objective: Validate restoration criteria and post-incident governance

Scenario narrative

The compromised workstation has been isolated, associated credentials have been revoked, and no additional suspicious messages are found in the queue. One recall request remains under review by a counterpart institution. Business leadership wants SWIFT-related operations restored quickly, but security advises that reconnecting high-trust payment assets before minimum assurance steps are completed may introduce further risk.

Information provided to participants

- Initial containment appears effective.
- No additional suspicious messages are identified.
- A limited set of legitimate high-priority payments remains delayed.
- Leadership requests a recommendation on restoration timing.

Discussion questions

- What minimum evidence or assurance is required before reconnecting or restoring the payment environment?
- Who signs off on service restoration?
- What monitoring or compensating controls must be added during the recovery period?
- What reporting, board-level, or regulatory obligations should be considered?
- What lessons learned should be captured immediately after the exercise scenario ends?

Expected actions

- Define restoration entry criteria and decision authority.
- Use enhanced monitoring and dual-review controls during reactivation.
- Document incident chronology, decisions, and residual risks.
- Prepare post-incident reporting and lessons learned.
- Assign remediation owners for access, queue review, anomaly detection, and payment continuity controls.

Facilitator notes

Focus on disciplined restoration, not speed alone. The key learning is whether the organization can articulate what “safe to reconnect” actually means for a high-trust payment environment.

9. Key Decision Points

- When should suspicious queued messages trigger formal incident escalation?
 - Should the organization isolate only the suspected workstation, or the broader SWIFT-connected environment?
 - Who has authority to halt or delay legitimate payment activity in the interest of fraud containment?
 - At what point should counterpart institutions be engaged for hold, reject, or recall actions?
 - What conditions must be satisfied before restoring normal payment operations?
-

10. Technical and Business Impacts

Technical impacts

- Potential compromise of a high-trust payment workstation
- Possible credential misuse and unauthorized message creation
- Risk of compromised approvals or queue manipulation
- Need for rapid evidence preservation across workstation, gateway, and logs

Business impacts

- Delayed treasury and settlement operations
 - Potential unauthorized cross-border fund movement
 - Client and correspondent-bank confidence risk
 - Regulatory, legal, and audit implications
 - Executive pressure to restore critical payment activity quickly
-

11. Facilitator Guide

Suggested facilitation flow

- 10 minutes: Introduction, objectives, and rules of engagement
- 15 minutes: Inject 1 discussion
- 20 minutes: Inject 2 discussion
- 20 minutes: Inject 3 discussion
- 15 minutes: Inject 4 discussion
- 10 minutes: Debrief, lessons learned, and action assignment

What to listen for

- Clear ownership of payment-halt authority
- Coordination between security and fraud functions
- Realistic manual payment continuity procedures
- Counterparty outreach readiness
- Restoration criteria that are specific and testable

Common gaps to surface

- Unclear authority to suppress queued payments
 - No well-rehearsed interbank recall process
 - Weak segregation of duties for payment creation and approval
 - Overreliance on technical teams for business decisions
 - Insufficient documentation for restoration sign-off
-

12. Debrief and Lessons Learned

Use the following prompts during the closing discussion:

- What was the first moment in the scenario when the organization should have treated this as suspected payment fraud rather than a routine system issue?
- Did participants know who could stop payment release immediately?
- Were communications between SOC, treasury, fraud, and legal clear and fast enough?
- Could the organization continue priority payments safely under manual or break-glass procedures?
- What changes are needed in queue review, alerting, privilege control, or correspondent-bank coordination?

Suggested after-action outputs

- Decision log and timeline
 - Gaps and risks register
 - Action plan with owners and due dates
 - Recommendations for control improvements and future exercises
-

13. MITRE ATT&CK Mapping

The STIX scenario does not explicitly enumerate ATT&CK techniques, so the mapping below reflects reasonable technique-level alignment inferred from the described behavior.

Tactics and techniques reflected in the scenario

- **Initial Access / Credential Access**

- **T1078 – Valid Accounts:** The adversary is described as using compromised credentials to access the payment workstation.

- **Execution / Defense Evasion / Persistence**

- **T1078 – Valid Accounts:** Continued use of legitimate credentials may allow the actor to blend into normal operations.

- **Lateral Movement / Remote Services (possible, inferred)**

- **T1021 – Remote Services:** If the workstation was accessed remotely using valid credentials, this technique may be relevant.

- **Collection**

- **T1213 – Data from Information Repositories:** Payment workflow information and message queues may be reviewed to select plausible fraudulent transactions.

- **Impact / Financial Theft Objective**

- **T1657 – Financial Theft:** The scenario's central objective is fraudulent transfer of funds through payment infrastructure.

ATT&CK notes for facilitators

- The strongest alignment is with **Valid Accounts (T1078)** and **Financial Theft (T1657)**.
 - Additional techniques may be discussed by participants depending on how they believe credentials were obtained or how access to the workstation was established.
 - Because the STIX bundle focuses on fraud execution rather than initial compromise tradecraft, ATT&CK mapping should be treated as indicative rather than exhaustive.
-

14. Optional Visuals for a Final PDF Layout

- A one-page scenario timeline with the four injects and decision points
- A swimlane view showing SOC, Treasury, Fraud, Legal, and Executive actions
- A simple diagram of the SWIFT-connected workstation, gateway, payment queue, and counterpart institutions
- A closing page summarizing top risks, lessons learned, and ATT&CK mapping